

Clase 193 — Detección de C2 y beaconing

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Applied Network Security Monitoring* — Sanders y Smith · MITRE ATT&CK (Command and Control)  Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Detectar canales de mando y control (C2) y su patrón de beaconing: las llamadas periódicas que un implante hace a su servidor. Aprenderás a reconocer regularidad temporal, jitter, dominios y fingerprints de frameworks como Cobalt Strike, y a cazar C2 sobre HTTP/S, DNS y protocolos comunes usando telemetría de red y endpoint.

 **Ética:** cualquier despliegue de C2 (p. ej. un teamserver de laboratorio) para generar telemetría se hace exclusivamente en tu entorno propio y aislado. El fin es construir detección defensiva.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

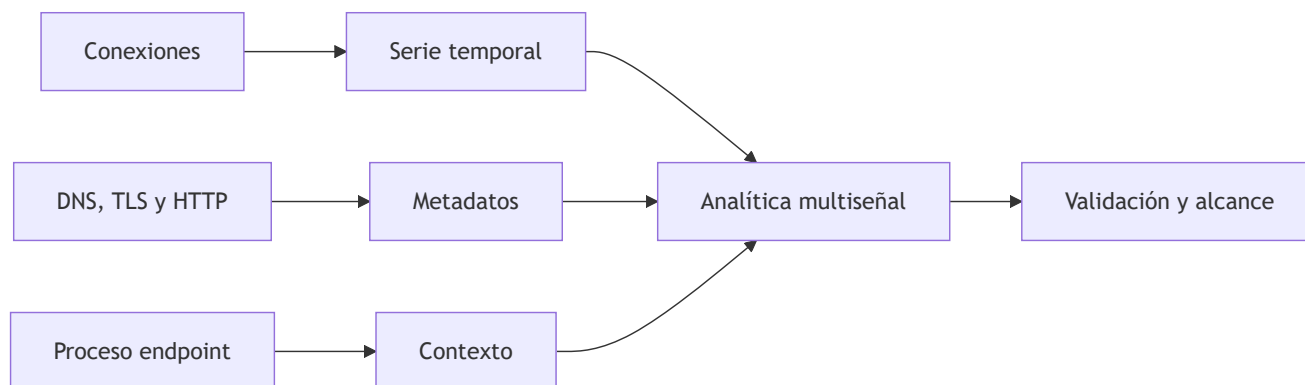
1. **Explicar** cómo funciona un canal C2 y qué es el beaconing (intervalo + jitter).
2. **Detectar** periodicidad de conexiones con análisis estadístico.
3. **Identificar** C2 sobre HTTP/S, DNS y dominios de malleable profiles.
4. **Usar** JA3/JA3S y fingerprints para detectar frameworks conocidos.
5. **Escribir** detecciones de C2 mapeadas a ATT&CK Command and Control.

Temas

#	Tema	Por qué importa
1	Anatomía de un canal C2	Entender qué detectar
2	Beaconing: intervalo y jitter	La huella temporal del implante
3	C2 sobre HTTP/S	Puede mezclarse con tráfico web permitido y exige correlación contextual
4	C2 sobre DNS	Evasión mediante resolución
5	Malleable C2 y evasión	Cómo se camuflan los frameworks
6	JA3/JA3S y fingerprints	Identificar herramientas
7	Análisis estadístico (RITA)	Detectar regularidad automáticamente
8	Correlación con endpoint	Atar el canal al proceso

Explicación en profundidad

El mando y control permite que una intrusión reciba instrucciones o envíe resultados. Un beacon periódico es solo una forma: puede usar jitter, permanecer inactivo, ocultarse en servicios compartidos o volverse interactivo. Buscar intervalos idénticos detecta implementaciones simples y omite variantes deliberadamente irregulares.



Se combinan regularidad, duración, asimetría de bytes, destino novedoso, rareza organizacional y proceso. Entropía de dominio o huella TLS no prueban C2: CDN, actualizadores y software empresarial producen patrones parecidos. La pregunta es si la relación host-proceso-destino concuerda con su función y con la actividad del endpoint.

Periodicidad, jitter y ventanas

Un beacon simple contacta cada intervalo. Se ordenan tiempos por entidad y destino, se calculan diferencias y se observa dispersión. Jitter ensancha esa distribución; por ello no se exige igualdad exacta. La ventana debe contener suficientes observaciones, pero una muy larga mezcla cambios de red y periodos de sueño. Frecuencia regular también aparece en monitoreo, NTP y actualizadores, así que el proceso y destino son decisivos.

El tráfico interactivo rompe periodicidad y puede aumentar bytes. Algunos canales usan long polling, servicios cloud o DNS; otros cambian dominios. La detección no debe depender de una única forma. Se construyen analíticas complementarias para relaciones raras persistentes, sesiones de baja transferencia, patrones DNS y conexiones de procesos inesperados.

Combinar red y endpoint

Una estación que consulta un dominio nuevo y establece TLS cada pocos minutos es un candidato. Si el EDR muestra que la conexión pertenece al navegador iniciado por el usuario, la explicación cambia; si pertenece a un proceso desde una ruta temporal cuyo padre fue Office, la confianza sube. Si el sensor de red está detrás de un proxy, la IP origen puede ser el proxy y la atribución requiere sus logs.

Bytes asimétricos no equivalen a exfiltración: un heartbeat suele enviar poco y recibir poco; una descarga legítima recibe mucho. Se estudian dirección, secuencia y rol del sistema. La reputación externa puede priorizar, pero un dominio sin reputación es desconocido, no benigno, y uno marcado requiere verificar tiempo y procedencia.

Límites de huellas y entropía

JA3 y otras huellas describen características observadas del cliente, no identidad estable del malware. Bibliotecas compartidas, cambios de TLS y evasión reducen su duración. La entropía de nombres puede señalar generación algorítmica, pero servicios legítimos crean identificadores largos. Estas señales aportan evidencia cuando coinciden con contexto, nunca una sentencia aislada. El resultado investigativo explica qué combinación disparó y qué alternativa benigna fue descartada.

HTTP/S: parecer normal no significa ser indistinguible

Un canal C2 puede usar métodos, rutas, cabeceras y tiempos semejantes a tráfico web. Frameworks con perfiles maleables permiten modificar esos elementos, por lo que una firma fija envejece. Aun así, la relación completa puede ser extraña: proceso que no debería navegar, destino nuevo, sesiones pequeñas persistentes, user-agent incoherente o certificado/contexto inusual. Se detecta la combinación y se preservan elementos que el adversario puede variar.

El cifrado protege contenido y también limita inspección. No se concluye qué comando viajó. Se correlacionan handshake/metadatos, DNS, flow, proxy y proceso. Si el tráfico usa un servicio cloud compartido, bloquear el dominio puede tener gran impacto; la respuesta puede centrarse en endpoint, identidad y objeto más específico.

DNS como canal

C2 sobre DNS puede codificar información en labels, variar tipos de registro o usar frecuencia anómala. Pero nombres largos y TXT no son por sí solos maliciosos. Se examinan volumen por cliente/dominio, proporción de respuestas, longitud, entropía, diversidad de subdominios, periodicidad y proceso. El resolutor recursivo puede ocultar cliente si la telemetría se toma en un punto incorrecto.

RITA y análisis estadístico

RITA procesa metadatos de red para resaltar patrones como beaconing y relaciones. Su score prioriza investigación; no certifica C2. La configuración, periodo y calidad de logs afectan resultados. El analista abre los candidatos, compara software legítimo, mira endpoint y documenta por qué uno se escala. Automatizar el ranking no automatiza la conclusión.

Malleability y resiliencia

Cuando el adversario cambia intervalos, dominios o TLS, una detección de un solo indicador puede caer. La estrategia mantiene capas: infraestructura con caducidad, características de protocolo, relación proceso-red y comportamiento temporal. Purple team puede variar un parámetro a la vez para comprobar cuál señal sobrevive y registrar la frontera real de cobertura.

Glosario

- **C2:** canal para controlar un implante.
- **Beacon:** comunicación recurrente de disponibilidad.
- **Jitter:** variación del intervalo.
- **Periodicidad:** repetición temporal medible.
- **Asimetría de bytes:** diferencia entre subida y bajada.
- **Destino novedoso:** contraparte sin historia suficiente.
- **DGA:** algoritmo que genera dominios.

Definiciones y características

- **C2 (Command and Control):** infraestructura desde la que el atacante controla los hosts comprometidos. Característica: prioriza sigilo y persistencia del canal.
- **Beacon:** implante que "llama a casa" periódicamente esperando órdenes. Característica: conexiones regulares de bajo volumen.
- **Jitter:** variación aleatoria del intervalo de beacon para evitar detección. Característica: dispersa la periodicidad, pero rara vez la elimina del todo.
- **Malleable C2:** perfiles que hacen que el tráfico imite servicios legítimos (jQuery, CDN). Característica: engaña inspecciones superficiales.
- **JA3/JA3S:** fingerprint del handshake TLS. Característica: algunos frameworks tienen JA3 característicos, detectables aun con cifrado.
- **DNS C2:** órdenes/datos codificados en consultas y respuestas DNS. Característica: alta cadencia de subdominios y registros TXT inusuales.
- **Domain fronting:** ocultar el destino real tras un dominio de CDN legítimo. Característica: SNI benigno con Host header distinto.

Análisis resuelto — periodicidad con jitter

Para un host se agrupan conexiones por destino y se ordenan tiempos. Un candidato presenta intervalos cercanos a cinco minutos, con variación de $\pm 20\%$. Se calculan mediana y dispersión; no se exige igualdad exacta. El tráfico intercambia pocos bytes y el destino es nuevo para ese host.

Antes de clasificar, se compara con inventario: los agentes de monitoreo tienen periodicidad semejante. El endpoint muestra que el candidato pertenece a un ejecutable en ruta temporal cuyo padre fue un documento, mientras el agente legítimo está firmado, instalado y usa destinos conocidos. DNS, TLS y proceso forman la evidencia conjunta.

Una segunda ventana muestra actividad interactiva que rompe el patrón. La detección basada solo en periodicidad la perdería, por lo que se mantiene otra analítica de relación rara proceso–destino. La huella TLS y entropía del dominio aportan contexto, no identidad.

Criterio de dominio

El alumno explica intervalos, jitter, ventana y baseline; descarta al menos una alternativa benigna; correlaciona endpoint; y declara límites de cifrado y visibilidad. Un dominio «raro» sin razonamiento no cumple.

Herramientas y preparación

En laboratorio aislado:

- **Zeek** (conn/dns/ssl.log) y **Suricata** como fuentes de red.
- **RITA** para análisis de beaconing y DNS tunneling sobre logs de Zeek.
- Un **framework C2 de laboratorio** para generar tráfico de prueba (p. ej. un teamserver propio o un simulador de beacon benigno).
- Tu SIEM y la telemetría Sysmon (Event 3 y 22) para correlación.

Nunca dirijas C2 real contra sistemas ajenos; todo el tráfico se genera y captura en tu red de pruebas.



Laboratorio guiado — Caza el latido del beacon

1. **Genera un beacon.** En laboratorio, configura un implante benigno que se conecte a un servidor propio cada 60 s con un jitter del 20%.
2. **Captura con Zeek.** Deja correr el tráfico varios minutos para acumular suficientes conexiones en conn.log.
3. **Analiza periodicidad.** Con RITA, importa los logs y ejecuta el análisis de beaconing; observa el score y el intervalo estimado.
4. **Detección manual.** En el SIEM, agrupa conexiones por par (origen, destino) y calcula la desviación de los deltas de tiempo: baja varianza = beacon.
5. **Prueba C2 sobre DNS.** Configura el implante para usar DNS; detecta la alta cadencia de subdominios y respuestas TXT largas.
6. **Fingerprint TLS.** Extrae el JA3 del cliente y compáralo con listas de frameworks conocidos.
7. **Correlaciona con endpoint.** Enlaza la conexión periódica (Sysmon Event 3) con el proceso responsable y su árbol (clase 189).
8. **Escribe la detección.** Crea una regla que alerte ante conexiones de baja varianza temporal y bajo volumen sostenidas a un mismo destino.



Ejercicios

1. Explica cómo el jitter dificulta la detección y por qué no la impide.
2. Calcula la varianza de intervalos de una serie de conexiones y decide si es beacon.
3. Diseña una detección de C2 sobre DNS basada en cadencia y entropía.
4. Describe cómo JA3 detecta un framework aun con TLS.
5. Explica el domain fronting y cómo lo delatarían SNI vs Host header.
6. Correlaciona un beacon de red con el proceso de endpoint que lo genera.



Reto verificable

Detecta un beacon generado en tu laboratorio combinando análisis temporal (periodicidad) y correlación con el proceso de endpoint. **Criterio de aceptación:** identificas el par origen-destino del beacon con su intervalo aproximado y jitter, justificas la detección con datos estadísticos (baja varianza), y enlazas la conexión con el proceso concreto que la origina en el host.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Servicios legítimos marcan como beacon	Telemetría, updates y sync también son periódicos; añade allowlist
Jitter alto evade tu regla	Umbral de varianza rígido; usa análisis estadístico (RITA) más tolerante
No ves C2 sobre DNS	Falta logging DNS; captura con Zeek/Sysmon 22
JA3 no identifica nada	Framework con perfil malleable; combina con periodicidad y volumen
Falsos positivos de CDN	Malleable/domain fronting; correlaciona SNI vs Host y con endpoint

Preguntas frecuentes

 **Si el C2 usa jitter, ¿es indetectable?** No. El jitter dispersa el intervalo, pero un beacon sigue siendo mucho más regular que la navegación humana. El análisis estadístico sobre suficientes muestras lo revela.

 **¿Puedo detectar C2 cifrado?** Sí, por metadatos: periodicidad, volumen, JA3, dominios y correlación con el proceso. No necesitas descifrar para reconocer el patrón de un implante.

 **¿Beaconing siempre es malicioso?** No. Actualizaciones, telemetría y sincronización también "laten". Por eso se combina periodicidad con reputación de destino, volumen y contexto de endpoint antes de escalar.

Referencias verificables y alcance

- MITRE ATT&CK, Command and Control: fuente primaria para el objetivo táctico y los procedimientos documentados — <https://attack.mitre.org/tactics/TA0011/>
- MITRE ATT&CK T1071: fuente primaria para protocolos de capa de aplicación utilizados por procedimientos de C2; el uso de HTTP o DNS también puede ser legítimo — <https://attack.mitre.org/techniques/T1071/>
- RITA: repositorio del proyecto y sus analíticas de metadatos; una puntuación de beaconing es una señal para investigar, no una atribución — <https://github.com/activecm/rita>
- JA3: repositorio original del método de huella TLS; documenta el cálculo, pero no convierte una coincidencia en veredicto — <https://github.com/salesforce/ja3>
- Sanders, C. y Smith, J. *Applied Network Security Monitoring*. Syngress: bibliografía complementaria para razonar con metadatos de red.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 192 — Detección de movimiento lateral](#)

Siguiente clase

[Clase 194 — Deception: honeypots y honeytokens](#)